

Security Analysis Report

eMagiz Ticketing System - Team 04

Executive Summary

This report analyzes the security aspects of the eMagiz Ticketing System. The system implements basic security measures including authentication, authorization, and data protection, but contains several vulnerabilities that should be addressed. Based on init testing, we detected input vulnerabilities, such as weak email pattern matching.

Security Controls Implemented

Authentication

- Token-based authentication with UUID tokens
- AuthFilter validates tokens for protected endpoints
- Public endpoints: login and password reset
- Token expiration: 24 hours for auth tokens, 30 minutes for reset tokens

Authorization

- Role-based access control (Support/Consultant/User)
- All API endpoints require authentication except public routes
- User Role is stored in request context for authorization decisions

Data Protection

- Password hashing using bcrypt with salt
- Tokens stored in database
- Passwords nullified in User objects after saving

Input Validation

- Basic null/empty checks for login
- JSON parsing for REST endpoints
- Possible email input vulnerability, working on implementing Regex to avoid such inputs as a@a

Security Vulnerabilities Identified

Medium Severity

1. Missing Rate Limiting

- Issue: No protection against brute force attacks

Low Severity

1. Insufficient Password Policy

- Issue: The system currently allows very simple passwords
- Recommendation: Implement password policy validation

2. Session Management Issues

- Issue: Tokens valid until expiration regardless of password changes
- Recommendation: Implement token invalidation on password change

Informational

1. Database Connection Exposure

- Issue: Unhandled Java exceptions might expose stack traces or database structures to the client.
- Recommendation: Improve error handling

Compliance with User Story Security Requirements

Based on requirements from reqs.txt:

- User Creation (with password hashing)
- Unique Identity (unique username constraint)
- Action Logging (implemented)
- Role-Based Access (roles stored and assignable)
- Ticket Validation (implemented)
- Ticket Assignment System (implemented)

Recommendations

Immediate Actions

1. Implement rate limiting on authentication endpoints
2. Improve error handling to prevent information leakage
3. Ensure password validation during user creation

Medium-term Actions

1. Review and improve session management (token invalidation on password change)
2. Implement proper input validation for email

Long-term Actions

1. Implement CI/CD pipelining.

Conclusion

During our security analysis, we found vulnerabilities, but also identified our strengths. Hashing password with Bcrypt and creating tokens with UUID works reliably. Regarding to our recommendations, we are working on email validation. All findings that are mentioned in this paper are actual state of the application.